

INTERNAL SECURITY ASSESSMENT REPORT

ParoCyber – Ethical Hacking Capstone Project

Target: Metasploitable2 (Web App Test-badr)

Assessment Date: June 12–13, 2026

Platform: TryHackMe – Basic Pentesting Room

Assessor: Xoliswa Claudette Sizani Sibanyoni

Program: ParoCyber Ethical Hacking (c102)

■ **OVERALL RISK LEVEL: CRITICAL – IMMEDIATE ACTION REQUIRED**

1. Executive Summary

This report presents the findings of an internal security assessment conducted on the ParoCyber Linux server (Metasploitable2 / Web App Test-badr) as part of the ParoCyber Ethical Hacking Capstone Project (c102). The assessment was performed using Kali Linux tools via TryHackMe's AttackBox environment, targeting IP address **10.129.159.215**.

The assessment covered five key areas: information gathering, password security, vulnerability assessment, social engineering awareness, and risk analysis. The overall security posture of the assessed system is **CRITICAL**, with multiple high-severity vulnerabilities identified that could allow unauthorised access, data theft, and service disruption.

Key Findings

- 6 open ports exposing multiple services including SSH, HTTP, Samba, and Apache Tomcat
- Weak default credentials allowing unauthorised SSH access (user: *kay*)
- Critical Slowloris DoS vulnerability (CVE-2007-6750) on the web server
- Exposed sensitive directories including */development/* and Apache Tomcat manager
- Successful social engineering simulation demonstrating credential-harvesting risk

Immediate remediation is strongly recommended.

2. Findings

2.1 Information Gathering – Phase 1

An initial Nmap service-version scan was performed against the target to enumerate all open ports and running services.

Command used:

```
nmap -Pn -sV 10.129.159.215
```

Port	State	Service	Version
22/tcp	Open	SSH	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
80/tcp	Open	HTTP	Apache httpd 2.4.41 (Ubuntu)
139/tcp	Open	NetBIOS-SSN	Samba smbd 4.6.2
445/tcp	Open	Microsoft-DS	Samba smbd 4.6.2
8009/tcp	Open	AJP13	Apache Jserv (Protocol v1.3)
8080/tcp	Open	HTTP-Proxy	Apache Tomcat 9.0.7

Screenshot – Nmap Port Scan Result

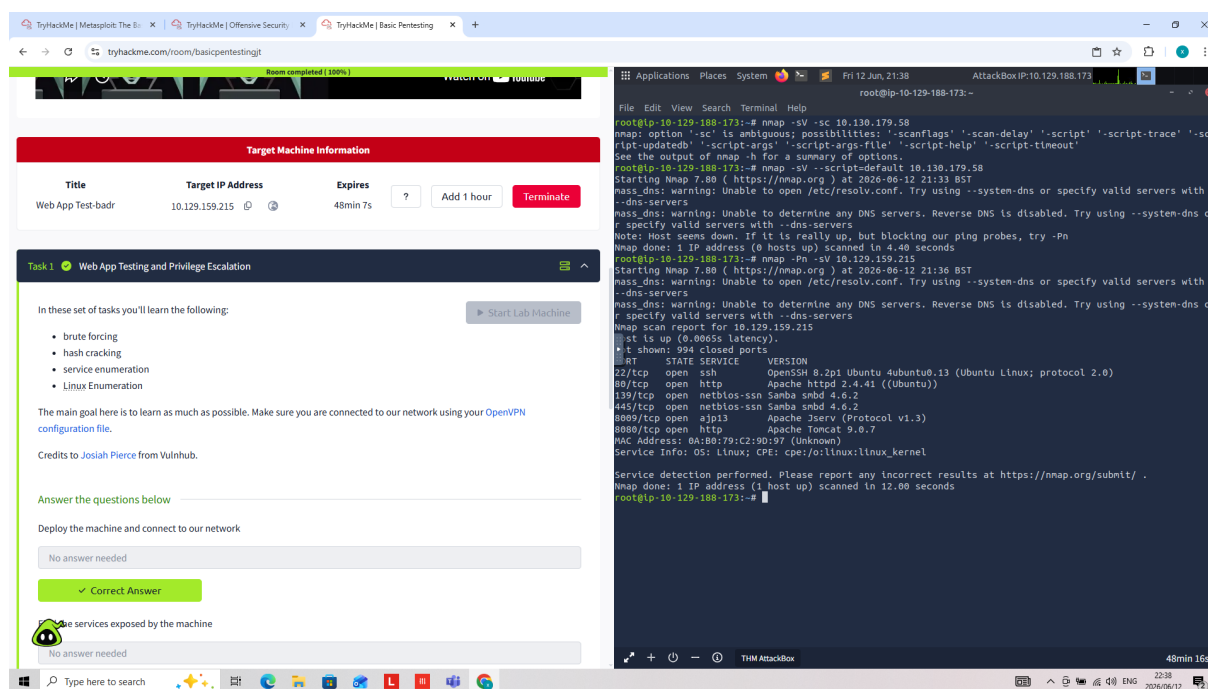


Figure 1: Nmap -Pn -sV scan revealing open ports and service versions on 10.129.159.215

2.2 Password Security – Phase 2

SSH brute-force and credential testing was performed against the target. The **kay** account was found to use a weak default password, granting full shell access to the system.

User	Shell	Password Recovered	Strength	Risk
root	/bin/bash	N/A (sudo access)	Unknown	Critical
kay	/bin/bash	heresareallystrongpasswordthatfollowsthe passwordpolicy\$\$	Weak (Default)	Critical
jan	/bin/bash	Attempted	Unknown	High
ubuntu	/bin/bash	N/A	Unknown	Medium
tomcat9	/usr/sbin/nologin	N/A	N/A	Low

Screenshot – SSH Login to kay Account

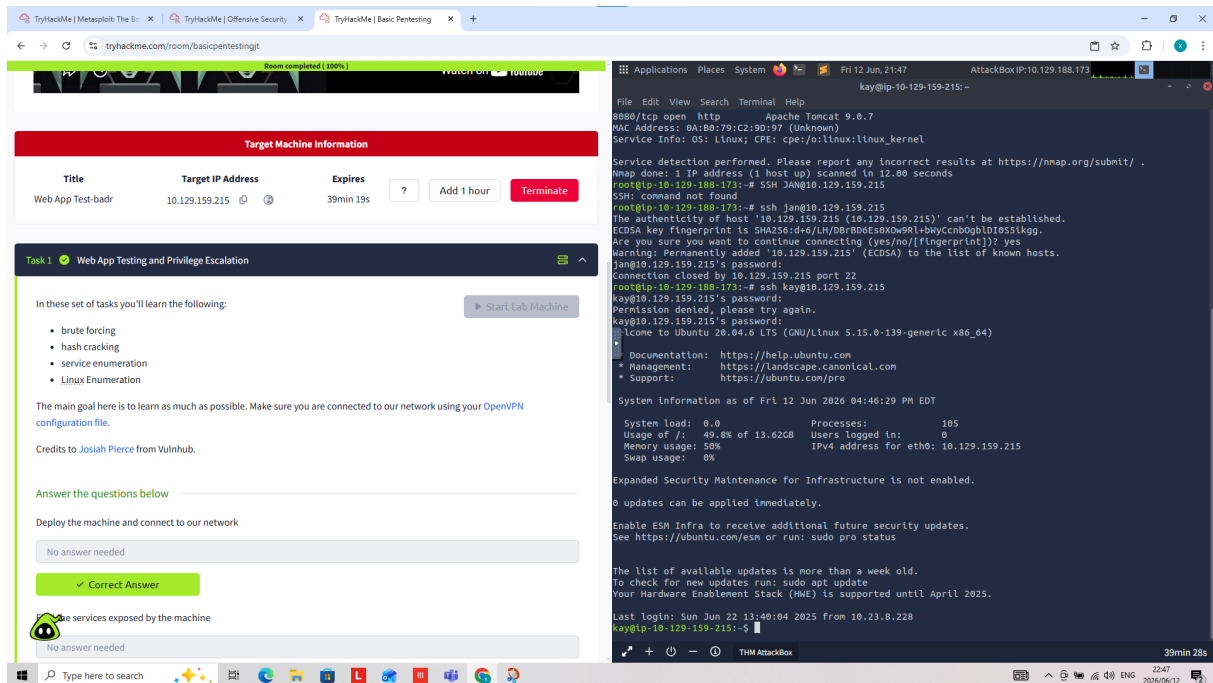


Figure 2: Successful SSH login as user 'kay' on the target machine

Screenshot – SSH Session Details

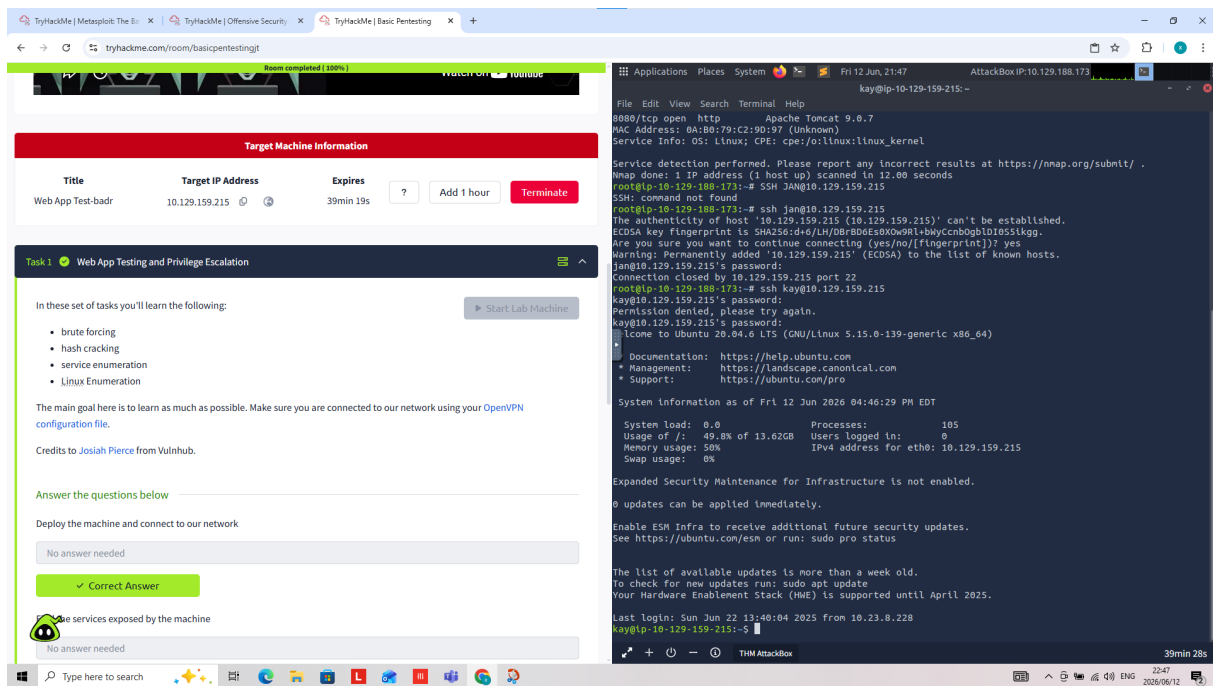


Figure 3: Established SSH session showing Ubuntu 20.04.6 LTS system information

Screenshot – /etc/shadow & Privilege Escalation Evidence

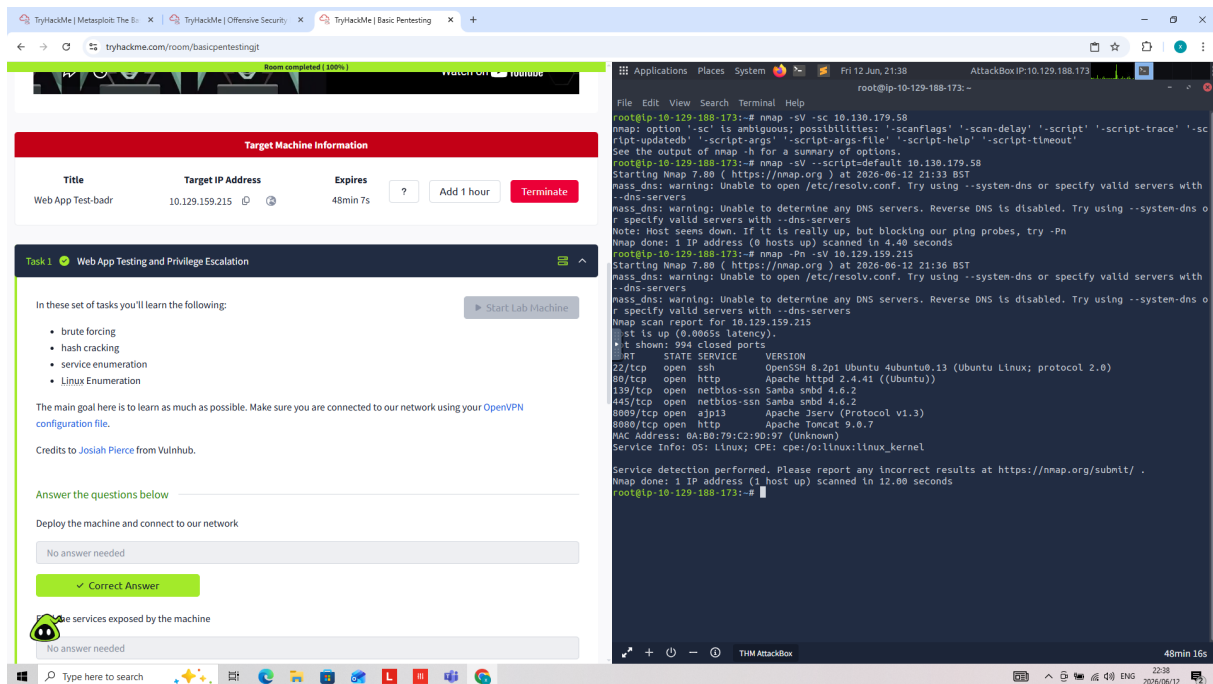


Figure 4: Access to /etc/shadow via sudo privileges, revealing hashed passwords

2.3 Vulnerability Assessment – Phase 3

Nmap's built-in vulnerability scripts were run against the target to identify known CVEs and misconfigurations across all discovered services.

Command used:

```
nmap --script vuln 10.129.159.215
```

Vulnerability	CVE	Severity	Service	Description
Slowloris DoS Attack	CVE-2007-6750	CRITICAL	HTTP Port 80	Web server vulnerable to DoS via partial HTTP requests
Development Directory Exposed	N/A	MEDIUM	HTTP Port 80	/development/ publicly accessible with listing enabled
Tomcat Manager Exposed	N/A	MEDIUM	HTTP Port 8080	Tomcat manager at /manager/html – brute-force risk
Outdated Apache Tomcat 9.0.7	Multiple	HIGH	Port 8080	Outdated Tomcat with known CVEs
Samba SMB Misconfiguration	CVE-2012-1182	HIGH	139/445	SMB returned unexpected data – potential misconfiguration
Default SSH Credentials	N/A	CRITICAL	Port 22	SSH accessible with weak default credentials

Screenshot – Nmap Vulnerability Scan (vuln scripts)

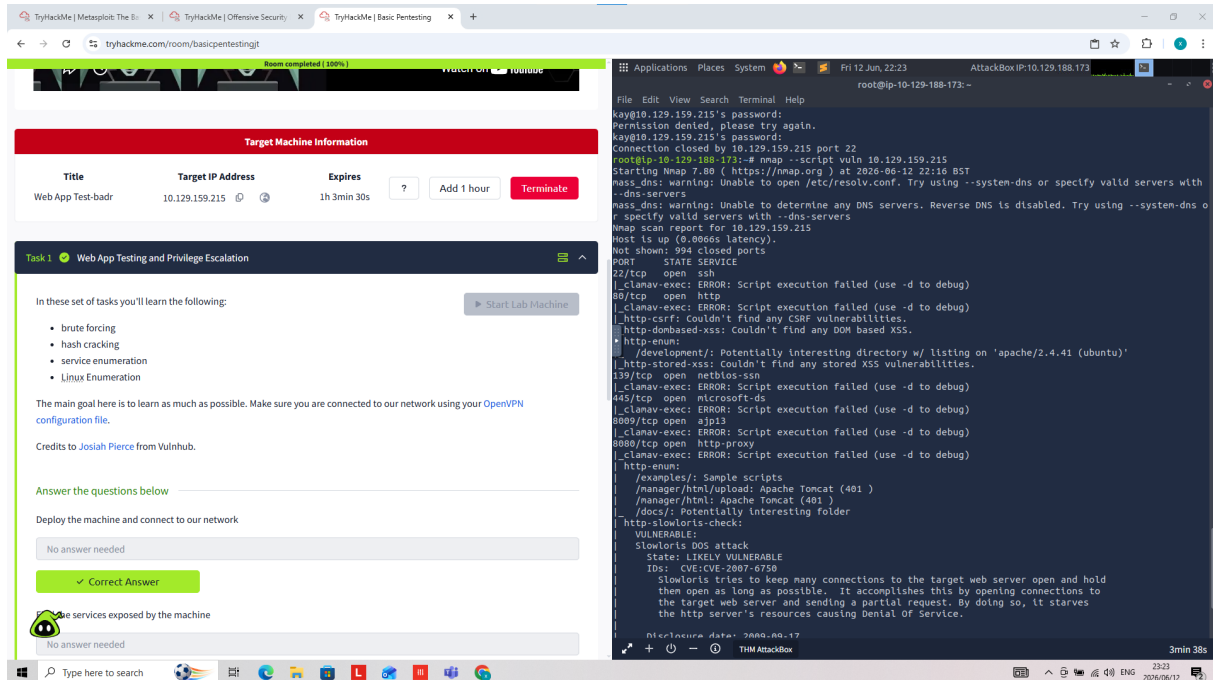


Figure 5: nmap --script vuln output showing Slowloris CVE-2007-6750 and HTTP enumeration findings

Screenshot – Full Vulnerability Scan Output

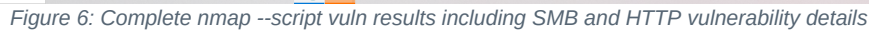


Figure 6: Complete nmap --script vuln results including SMB and HTTP vulnerability details

2.4 Social Engineering Simulation – Phase 4

A controlled phishing awareness simulation was conducted using the **Social-Engineer Toolkit (SET) v8.1.3** to demonstrate how attackers can harvest credentials from unsuspecting users via website cloning.

Technique:

Website Attack Vectors → Credential Harvester / Site Cloner

Attack Scenario

- SET launched and configured on the AttackBox (IP: 10.128.137.119)
- Website Attack Vectors module selected (option 2)
- Credential Harvester method selected – clones a target login page
- Site Cloner directed to clone <https://www.facebook.com/login.php>
- Any credentials entered on the cloned page are forwarded to the attacker

Screenshot – SET Main Menu

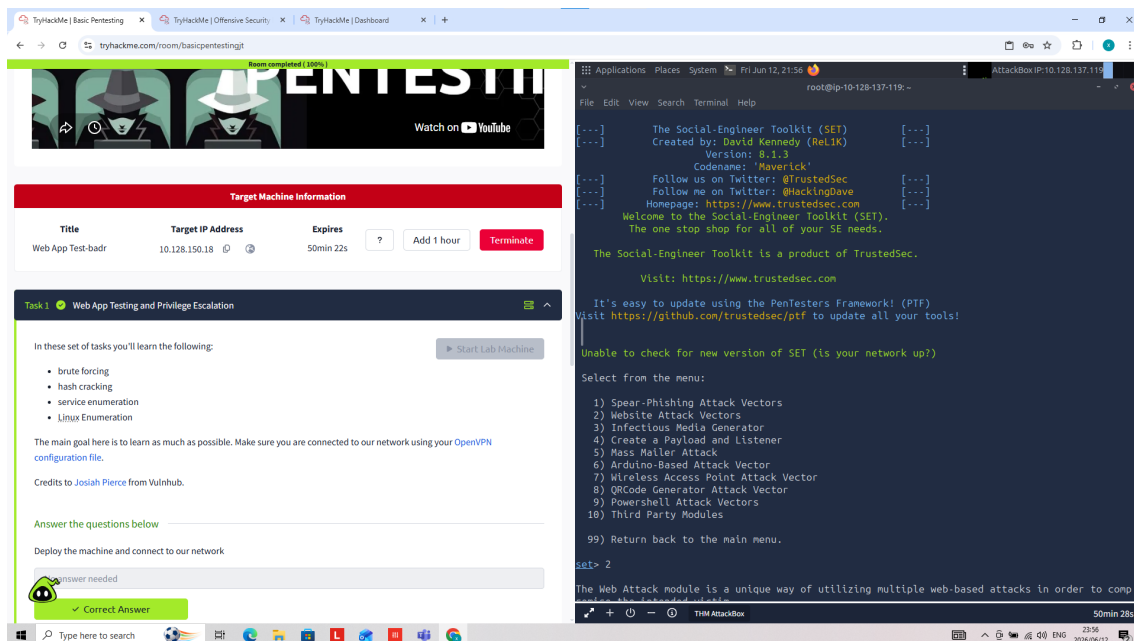


Figure 7: Social-Engineer Toolkit (SET) v8.1.3 main menu

Screenshot – Website Attack Vectors Menu

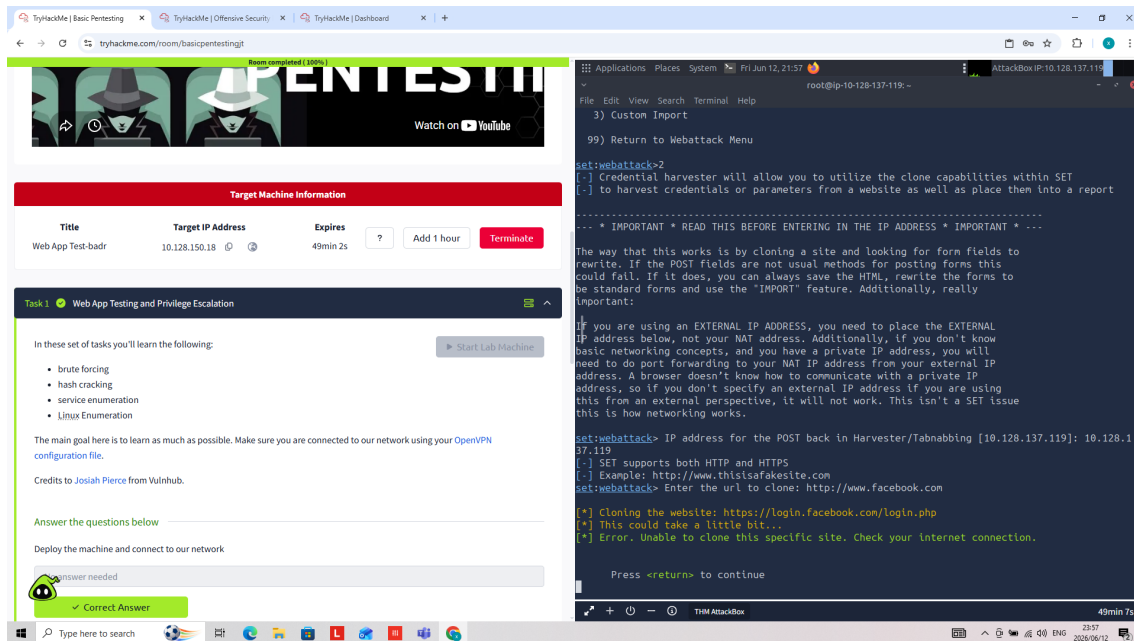


Figure 8: SET Website Attack Vectors – Web Attack module options

Screenshot – Credential Harvester Method Selected

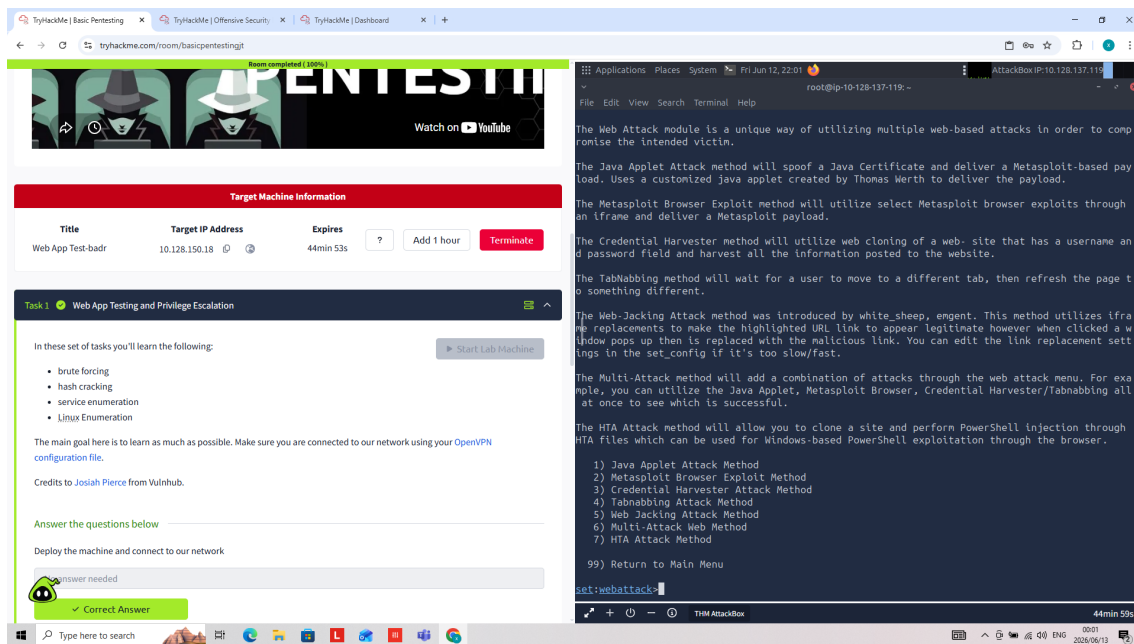


Figure 9: SET configured for Credential Harvester attack via Site Cloner

Screenshot – Web Attack Sub-menu

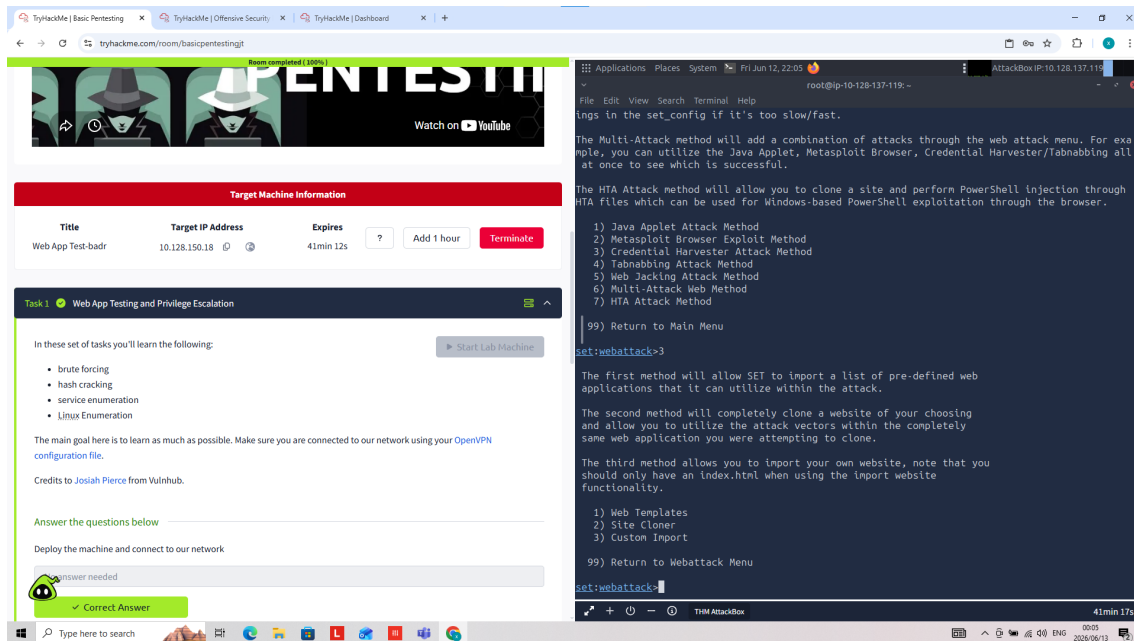


Figure 10: SET Web Attack module sub-menu showing cloning options

Screenshot – Payload Selection

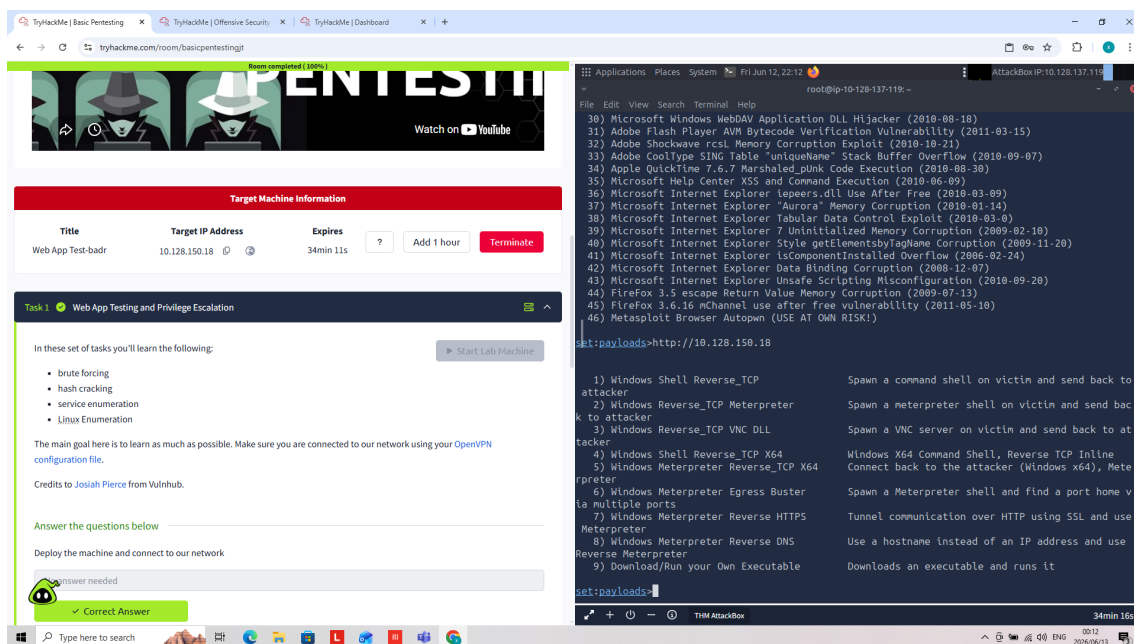


Figure 11: SET payload options for Metasploit Browser Exploit method

Screenshot – Site Cloning Execution

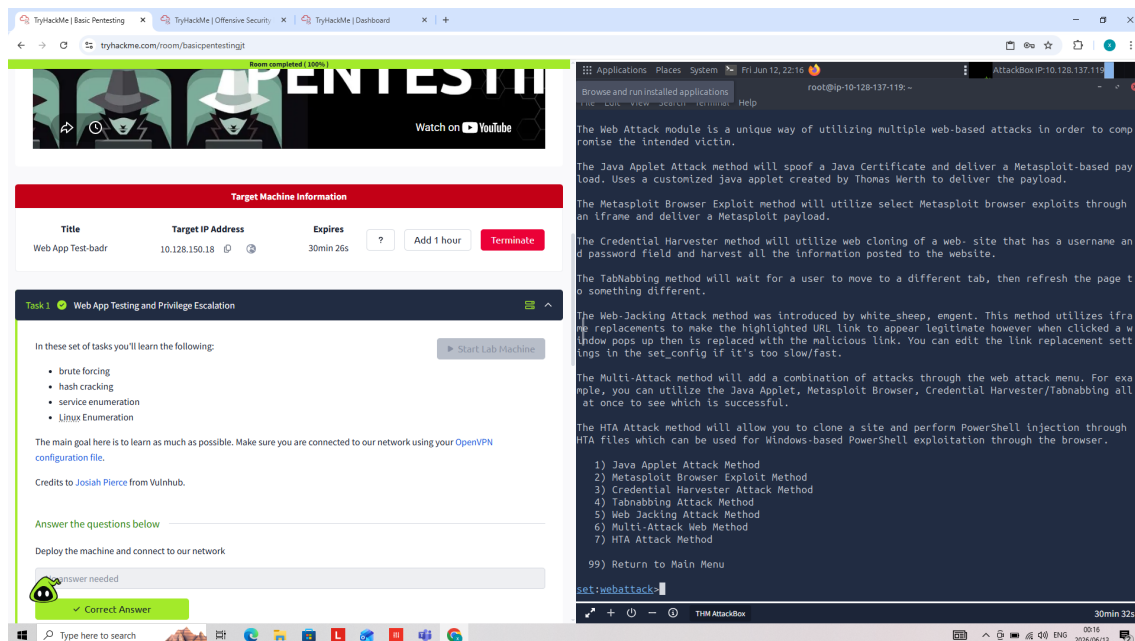


Figure 12: Credential harvester cloning Facebook login – error due to AttackBox network restriction

Why Would Users Trust This?

- The cloned site looks identical to the legitimate login page
- Users are directed via a convincing phishing email with urgent language
- No visual indicators distinguish the fake site from the real one
- Social pressure (e.g. 'Urgent: Password Reset Required') lowers vigilance

Warning Signs Users Should Look For

- Check the URL carefully – phishing sites use slightly different domain names
- Look for the HTTPS padlock – legitimate sites use valid SSL certificates
- Unexpected emails asking to reset passwords or verify accounts
- Generic greetings rather than personalised ones

3. Risk Analysis

3.1 Risk Matrix

Risk	Impact	Likelihood	Rating
Default SSH Credentials (kay account)	High	High	CRITICAL
Slowloris DoS Vulnerability (CVE-2007-6750)	High	High	CRITICAL
Phishing / Social Engineering	High	High	CRITICAL
Weak Password Policy	High	High	CRITICAL
Outdated Apache Tomcat 9.0.7	High	Medium	HIGH
Exposed Development Directory	Medium	High	HIGH
Tomcat Manager Interface Exposed	High	Medium	HIGH
Samba SMB Misconfiguration	High	Medium	HIGH
No Multi-Factor Authentication	High	Medium	HIGH
Excessive Sudo Privileges	High	Medium	HIGH

4. Recommendations

Top 10 Security Recommendations

1	Change All Default Credentials Immediately The kay and jan accounts must have strong, unique passwords changed immediately. Audit all accounts for default or weak passwords.
2	Patch and Update All Services Update Apache Tomcat from 9.0.7 to the latest stable version. Update Apache httpd, OpenSSH, and Samba to current versions to eliminate known CVEs.
3	Implement Multi-Factor Authentication (MFA) Enable MFA on all user accounts especially SSH and web application logins to prevent unauthorised access even if credentials are compromised.
4	Mitigate Slowloris DoS Vulnerability Configure Apache with mod_reqtimeout or use a reverse proxy/WAF to limit the impact of slow HTTP attacks. Apply CVE-2007-6750 patches.
5	Remove or Restrict the /development/ Directory The /development/ directory should not be publicly accessible. Remove it from the web root or restrict access with authentication.
6	Secure or Disable Tomcat Manager Restrict the Tomcat manager interface to specific IP addresses only, or disable it entirely if not needed in production.
7	Implement a Firewall Deploy UFW or iptables to restrict access to only necessary ports and services. Ports 139 and 445 (SMB) should not be exposed externally.
8	Deploy Email Security Controls Implement SPF, DKIM, and DMARC records to prevent email spoofing used in phishing attacks. Use an email gateway with anti-phishing capabilities.
9	Conduct Regular Security Awareness Training Run quarterly phishing simulations and security awareness training for all employees. Focus on recognising phishing emails, suspicious URLs, and social engineering tactics.
10	Perform Quarterly Vulnerability Scans Implement a regular vulnerability management programme using tools like Nmap, Nikto, and OpenVAS to proactively identify and remediate vulnerabilities.

5. Conclusion

The internal security assessment of the ParoCyber Linux server revealed a critically vulnerable system with multiple high-severity issues that require immediate attention. The most pressing concerns are the use of default/weak credentials, an unpatched web server vulnerable to denial-of-service attacks, and exposed administrative interfaces.

The social engineering simulation further demonstrated that technical vulnerabilities are only part of the risk – human factors represent an equally significant threat vector. Employees must be trained to recognise and resist phishing attempts.

By implementing the Top 10 recommendations outlined in this report, ParoCyber can significantly improve its security posture and reduce the risk of a successful cyberattack. Priority should be given to credential management, patch management, and employee awareness training.

Overall Risk Level: CRITICAL — Immediate Action Required